

QT-AI 전체 코드 리뷰 — 조치 계획서

이슈 정리 · 처리 체크리스트 · 담당자 배정 | 2026-06-05 | 작성: Lead 강태오 (리뷰 기준 커밋 be88e9e = origin/dev 최신)

요약

우선순위	의미	건수	목표
P0	지금 실제로 동작하지 않는 기능 — 즉시 수정	9	이번 주
P1	데이터 정합 · 보안 · 계약 결함 — 빠른 시일 내	13	1~2주
P2	MSA 분리 준비 — 차단 요소 해소 · 설계 결정	8	분리 착수 전
P3	위생 — 죽은 코드 · CI 게이트 · 문서 현행화	5그룹	상시

리뷰 범위: 서버 main 629개 Java 전부 + 테스트 + 마이그레이션 V1~V23 + CI/compose + Flutter 88개 dart 전부. 핵심 발견 17건은 코드 원문 재검증 완료. 상세 근거는 reports/2026-06-05_full-codebase-review_report.md 참조.

팀 구성 · 도메인 담당 (CODEOWNERS 기준)

팀원	담당 영역
강태오 (Lead, @Tae0072)	member · qt · admin · audit, 인프라/CI/공통(common · security), 전 도메인 지원
이지윤 (DevA, @ij447504-source)	note(설교노트), bible · report · notification · mission 공동, Flutter 공동, 데이터 소스
김태혁 (DevB, @xogurrrh012)	study(시뮬레이터)
강상민 (DevC, @sangminka)	ai 전체, study(해설 · 용어 공동)
이승욱 (DevD, @LeeSeung-Wook)	praise, sharing 공동, note · bible · report · notification · mission 공동, Flutter 공동, SecurityConfig(JWT)
김지민 (DevE, @rmfdnjf98)	sharing 공동, note(자유/나눔), bible · report · notification · mission 공동, Flutter 공동

담당자별 배정 한눈표

팀원	P0 (즉시)	P1 (1~2주)	P2 (MSA)	P3 (위생)
강태오	P0-1 · 2 · 3 · 4(qt) · 7(연계) · 8	P1-1 · 4 · 5 · 6 · 7(공동) · 8	P2-1 · 2 · 3 · 4 · 5 · 8	P3-2 · 4 · 5
이지윤	P0-6 · 7 · 9	P1-9 · 10 · 12 · 13	P2-2(적용)	P3-1(소유분) · 3
김태혁	P0-4(study)	P1-11	P2-6	P3-1(study)
강상민	P0-1(협조) · 2(ai)	P1-3 · 11	P2-6 · 7	P3-1(ai)
이승욱	P0-1(협조) · 5 · 6(sharing) · 7 · 9	P1-1(적용) · 2 · 7 · 9 · 12 · 13	P2-3(적용)	P3-1(소유분) · 3
김지민	P0-5 · 6 · 7 · 9	P1-1(적용) · 2 · 9 · 10 · 12 · 13	P2-3(적용)	P3-1(소유분) · 3

※ 공동 담당 항목은 첫 번째 표기자가 주담당. 모든 작업은 dev 기준 브랜치 {type}/{scope}-{설명} + PR(10파일/500라인 이하) 규칙을 따른다. F-ID 관련 기능은 PR에 F-ID 명시.

P0 — 즉시 수정 (기능 동작 회복) · 9건

[Critical] P0-1 관리자 세부 권한(ADMIN_ROLE_*) 발급 코드 부재 — 관리자 API 전멸

문제 ADMIN_ROLE_OPERATOR/REVIEWER/SUPER_ADMIN 권한을 검사하는 곳은 4곳인데 발급하는 곳이 0곳. JWT 필터는 ROLE_ADMIN 하나만 부여한다. 운영 토큰으로는 신고 처리·감사 조회·AI 자산 승인이 전부 403. CLAUDE.md § 5의 admin_users.admin_role DB 검증도 어디서도 수행되지 않는다(테스트는 권한을 수동 주입해 통과 → CI 미검출).

- ☐ 검증 방식 확정 — JWT claim 추가 vs VerifyAdminRoleUseCase(DB 조회) 통일. DB 방식 권장(계정 비활성 즉시 반영, § 5 부합)
- ☐ AdminAiAssetController·AdminAiAuthentication·AdminAuditAuthentication·AdminReportController 4곳을 확정 방식으로 교체
- ☐ admin_users.status(DISABLED) 검증 포함
- ☐ 실제 JWT 발급 → admin API 호출 통합 테스트 추가(권한 수동 주입 방식 금지)
- ☐ 권한 검증 헬퍼 4중 복불 제거 — security 공통 헬퍼로 승격

담당 강태오(설계·admin) · 이승욱(security) · 협조: 강상민(ai web), 김지민·이지윤(report/audit 적용)

위치 security/JwtAuthenticationFilter, domain/{ai,audit,report}/web

[Critical] P0-2 00:05 AI 해설 시딩이 항상 '어제' 본문을 시딩

문제 시딩 배치가 사용자용 getToday()를 호출하는데, 이 API는 00:00~04:00에 무조건 어제 본문(STALE_FALLBACK)을 반환. 어제 본문은 이미 처리돼 전부 skip → 오늘 본문 해설 job은 그날 안 만들어지고 04:00 노출 사이클을 항상 놓침. SU 본문 수집 스케줄러와 같은 00:05 cron이라 순서 보장도 없음.

- ☐ qt에 캐시·STALE 정책을 우회하는 내부용 '특정 날짜 본문 조회' UseCase 신설
- ☐ 시딩 서비스가 내부용 조회(오늘 날짜)를 쓰도록 변경
- ☐ SU 수집(00:05)과 시딩 순서 보장 — 시딩을 00:20으로 이동하거나 수집 완료 후 트리거
- ☐ 본문 부재·실패 시 재시도 정책 추가(현재 1회 시도 후 종료)
- ☐ 00:00~04:00 시각 고정 시딩 날짜 검증 테스트 추가

담당 강태오(qt) · 강상민(ai)

위치 qt/internal/QtPassageLookup, ai/internal/AiDailyQtVerseExplanationSeed*,

qt/internal/SuTodayPassageImportScheduler

[Critical] P0-3 qt_passage_verses를 채우는 코드가 없음 — AI·학습 파이프라인 단절

문제 SU 자동 수집은 qt_passages 행만 만든다. 해설 시딩·학습 콘텐츠·시뮬레이터가 쓰는 verselds는 전부 qt_passage_verses 조인에서 나오므로, 자동 수집 본문은 해설 job 0건·학습 콘텐츠 빈 목록. 현재 동작하는 것은 V8 수동 시드 3건뿐.

- ☐ SU import 시 start_verse~end_verse 범위를 bible api로 verse id 매핑해 qt_passage_verses 저장
- ☐ 기존 수집본 백필(1회 배치 또는 마이그레이션)
- ☐ '범위 컬럼 vs 매핑 테이블' 진실의 원천 문서화
- ☐ 수집 → 시딩 → 학습 콘텐츠 E2E 테스트 추가

담당 강태오(qt) · 협조: 바이블 그룹(bible api 보강)

위치 qt/internal/QtTodayPassageImportService, bible/api

[Critical] P0-4 Today QT 해설·시뮬레이터 양방향 단절 — 'Today QT 100%' 미충족

문제 서버: simulatorStatus="MISSING", hasExplanation=false 하드코딩(study에 판정 로직이 이미 구현돼 있는데 qt가 호출 안 함). Flutter: 세 필드를 파싱조차 안 하고 버튼은 qtPassageId=null 고정 비활성, 노트 버튼은 빈 핸들러. 콘텐츠가 승인돼도 사용자 진입점이 전부 닫혀 있음.

- ☐ study에 경량 상태 조회 UseCase(GetSimulatorStatus 등) 신설, qt가 호출해 실패 반환
- ☐ 하드코딩 제거 + DISABLED(운영 비활성) 반환 조건 구현 — 현재 도달 불가 enum
- ☐ todayQt 캐시에 상태가 박제되는 문제 처리(상태 필드는 캐시 제외 또는 짧은 TTL)
- ☐ Flutter: simulatorStatus/hasExplanation/draftNoteId 파싱 + READY일 때만 버튼 활성화
- ☐ Flutter: 노트 작성 버튼 핸들러 연결, 미지 상태값 방어(unknown → 비활성)
- ☐ qt→study 연동 통합 테스트 + Flutter 위젯 테스트

담당 강태오(qt) · 김태혁(study) · Flutter: 김지민·이승욱·이지윤

위치 qt/internal/QtPassageLookup·QtService, study/api, flutter bible_models·today_qt_screen

[Critical] P0-5 댓글 목록 — 탈퇴 회원 1명이면 글 전체 댓글 API 404 (+N+1)

문제 댓글마다 getMemberPublic()을 호출(N+1)하는데, 이 메서드는 탈퇴 회원에 MEMBER_NOT_FOUND를 던짐 → 탈퇴자 댓글이 하나라도 있으면 목록 전체 실패. 탈퇴자 글·댓글은 2년 보존이라 시간이 갈수록 깨지는 글 누적.

- ☐ 댓글 작성 시점 닉네임 스냅샷 컬럼 추가(권장) 또는 벌크 조회 + 탈퇴자 '(탈퇴 회원)' 폴백
- ☐ member에 벌크 공개 프로필 조회 계약 추가(MSA 분리 대비)
- ☐ 탈퇴 회원 댓글 포함 목록 조회 테스트 추가

담당 김지민·이승욱(sharing) · 강태오(member 계약 협의)

위치 sharing/internal/CommentService, member/api/GetMemberUseCase

[Critical] P0-6 노트 삭제 ↔ 나눔글 연동(source_note_unshared_at) 전체 미구현

문제 쓰는 코드가 0건(읽기만 3곳). 노트를 삭제해도 나눔글은 영구 PUBLISHED + '원본 삭제 안내' 분기 영구 미동작. 명세 § 4.3.7 위반.

- ☐ note 삭제 시 sharing 통지 구현(UseCase 호출 또는 도메인 이벤트)
- ☐ sourceNoteUnsharedAt 기록 + 상세 응답에 원본 삭제 안내 반영
- ☐ HIDDEN 자동 전환 여부 정책 확정(엔티티 주석과 명세 충돌 정리 — Lead 결정)
- ☐ 노트 삭제 → 나눔 상세/목록 동작 테스트

담당 이지윤·김지민(note) · 김지민·이승욱(sharing)

위치 note/internal/NoteService, sharing/internal/SharingPostService

[Critical] P0-7 신고 처리(resolve)가 빈 껍데기 + 처리자 ID 의미 오류

문제 상태 전이만 하고 대상 숨김·신고자 알림·감사 기록 전부 TODO. 또 processedByAdminId에 JWT principal(members.id)을 저장하는데 DDL FK는 admin_users.id → 운영 MySQL에서 FK 위반 500 또는 데이터 오염(audit actor_id도 동일 계열).

- ☐ processedByAdminId/actor_id에 adminUserId 기록(P0-1의 VerifyAdminRoleUseCase 반환값 사용)
- ☐ HIDE_TARGET: sharing 관리자 강제 숨김 UseCase 신설·연동
- ☐ notifyReporter: notification.SendNotificationUseCase(REPORT_RESULT) 호출 연결
- ☐ 처리 시 audit_logs 기록 추가
- ☐ FK 위반 vs 중복 신고(R0001) 예외 구분 처리
- ☐ 신고 접수→처리 E2E 테스트(숨김·알림·감사 포함)

담당 김지민·이승욱·이지윤(report) · 강태오(admin/audit 연계)

위치 report/internal/AdminReportService, report/web/AdminReportController

[Critical] P0-8 qt 단건 조회 공개 게이트 없음 — 미래 본문 선노출

문제 `getPassage/getContentContext`가 날짜 검사 없이 row만 있으면 반환(`published=true` 하드코딩). 선등록된 내일 본문을 id 순회로 미리 열람 가능 — § 6 '00:00 KST 공개' 우회. 승인 해설·클립도 미래 본문 것이 study 경로로 노출.

- ☐ 공개 게이트(`qtDate` 기준, 00:00/04:00 정책 반영)를 두 진입점에 적용
- ☐ `published` 판정을 qt 단일 책임으로 통일(하드코딩 제거)
- ☐ 미래 날짜 차단 테스트 추가(§ 10 필수 항목)

담당 강태오(qt)

위치 `qt/internal/QtService.getPassage·getContentContext`

[Critical] P0-9 Flutter 기동·로그인 차단 3종(iOS 카카오킬러/cleartext/가짜 본문)

문제 ① iOS Info.plist에 카카오킬러 URL scheme 설정이 전무 — iOS 로그인 불가. ② dev base URL이 http인데 cleartext 허용 없음 — API 28+에서 전 API 차단. ③ 서버 range가 null이면 하드코딩된 '고린도전서 1:10-17'을 오늘 QT처럼 표시 — 잘못된 말씀 노출.

- ☐ Info.plist에 `CFBundleURLTypes(kakao{KEY})·LSApplicationQueriesSchemes` 추가
- ☐ Android debug에 `networkSecurityConfig(cleartext 허용)` 추가
- ☐ Manifest 카카오킬러 redirect scheme을 `manifestPlaceholders`로 dart-define과 연동
- ☐ 하드코딩 fallback 본문 제거 → '준비 중/오류' UI로 대체
- ☐ release 서명·`applicationId` TODO 정리

담당 김지민·이승욱·이지윤(Flutter)

위치 `ios/Runner/Info.plist, android/AndroidManifest.xml, lib/features/bible/services/bible_repository.dart`

P1 — 빠른 시일 내 (정합·보안·계약) · 13건

[High] P1-1 동시 요청 UNIQUE 위반이 500으로 누출(409 계약 위반)

문제 `sharing publish/like, note 수정 전환, member settings` 첫 생성, study 해설 `publish`가 사전 `exists` 검사만 하고 `DataIntegrityViolationException`을 안 잡음 → 더블탭/재시도에서 500. `praise`만 catch(도메인 간 불일치).

- ☐ `GlobalExceptionHandler`에 DIVE 공통 매핑 추가 또는 도메인별 catch 통일
- ☐ `sharing→S0003/S0004, note→N0002, settings/study→적정 코드로 변환`
- ☐ 동시 요청(2-thread) 테스트 추가

담당 강태오(common) + 각 도메인 담당 적용

위치 `common/exception/GlobalExceptionHandler` 외

[High] P1-2 좋아요·댓글 카운터 lost update + purge 후 영구 drift

문제 COUNT 재계산+dirty checking 패턴이라 동시 요청 시 카운터가 실제 행 수와 어긋남(보정 배치 없음). 탈퇴자 purge도 타인 글 카운터 미보정.

- ☐ 원자 UPDATE(`SET like_count = like_count±1` 또는 서브쿼리 동기화)로 교체
- ☐ purge 시 영향 글 카운터 재계산 추가
- ☐ 음수 방지·동시성 테스트

담당 김지민·이승욱(sharing)

위치 `sharing/internal/SharingPostService·SharingPurgeService`

[High] P1-3 AI 워커 안정화(RUNNING 고착·tx 내 LLM·주체 미기록)

문제 워커 크래시 시 job이 RUNNING 영구 고착 + unique key로 재생성도 차단. 검증용 LLM 호출(최대 30초)이 DB 트랜잭션 안. requested_by 기록 의무 (§ 7) 미이행. ai_prompt_versions 시드 부재로 첫 배포 시 시딩 매일 실패.

- ☐ started_at 타임아웃 기반 RUNNING→FAILED 스왑 배치 추가
- ☐ 검증 LLM 호출을 트랜잭션 밖으로 분리
- ☐ requested_by_admin_id 엔티티 매핑 + SYSTEM_BATCH/admin 주체 기록
- ☐ completeSucceeded/Failed 예외의 per-job 격리(루프 중단 방지)
- ☐ ai_prompt_versions ACTIVE 시드 마이그레이션 추가
- ☐ layer2 NEEDS_REVIEW 재검증 진입점 신설(현재 승인 영구 불가)

담당 강상민(ai)

위치 ai/internal/AiGenerationJobRunner·AiService·AiReviewValidationService

[High] P1-4 임시 닉네임 fallback 24자 > VARCHAR(20) — 가입 영구 실패 가능

문제 user_{10자리kakaoid}_{UUID8}=24자. 닉네임 선점 시 INSERT 실패가 KAKAO_AUTH_FAILED(401)로 둔갑, 해당 사용자는 가입 불가.

- ☐ 길이 보장 생성 규칙으로 교체(suffix 축소·재시도)
- ☐ user_prefix 예약어 검증 추가(닉네임 변경 API)
- ☐ DIVE 원인(닉네임 vs kakao_id) 구분 처리

담당 강태오(member)

위치 member/internal/AuthService.registerNewMember

[High] P1-5 테스트 RSA 개인키 평문 커밋 + .env.example이 시연용으로 안내 (§ 8 위반)

문제 동일 키쌍이 테스트 yml 2곳에 커밋, gitleaks allowlist로 우회. .env.example이 '시연은 테스트 키 그대로'라 안내해 런타임 키로 승격.

- ☐ 커밋 키 폐기·회전(테스트는 부트 시 동적 키 생성 또는 fixture 생성 스크립트)
- ☐ .env.example 안내 수정 + 시연용 키 생성 스크립트 분리
- ☐ gitleaks allowlist 범위 재검토

담당 강태오(인프라)

위치 src/test/resources/application*.yaml, .env.example, .gitleaks.toml

[High] P1-6 시연 compose가 무인증(dev-bypass)으로 8080 노출

문제 루트 docker-compose가 dev 프로파일 기동 → 전체 permitAll + X-Dev-User-Id 위장 가능.

- ☐ 시연용 prod-like 프로파일(인증 ON) 제공 또는 무인증 시연을 명시 결정으로 기록
- ☐ compose 2종(루트/qtai-server) 중복·포트 충돌 정리 — qtai-server쪽은 local(H2) 모순이라 삭제 권장

담당 강태오(인프라)

위치 docker-compose.yml, qtai-server/docker-compose.yml

[High] P1-7 Security 구성 갭 — CORS 미설정·프로파일 빈틈·H2 콘솔

문제 SecurityConfig에 .cors() 부재 → 관리자 웹(별도 오리진) preflight 401. dev+bypass=false 조합은 시큐리티 체인 0개(Boot 폼로그인 폴백) = dev에서 정식 JWT 테스트 불가. local 프로파일 H2 콘솔 401(주석 TODO 미이행).

- ☐ .cors(withDefaults()) + CorsConfigurationSource(관리자 웹 오리진 설정) 추가
- ☐ 프로파일 재설계 — dev에서 bypass=false면 SecurityConfig가 활성화되도록(@Profile 대신 @ConditionalOnProperty 등)
- ☐ local에 /h2-console permitAll + frameOptions(sameOrigin)
- ☐ /api/v1/system/**를 필터 레벨 hasAuthority(ROLE_SYSTEM_BATCH)로도 보호(현재 컨트롤러 수동 검사 의존)

담당 이승욱(security) · 강태오

위치 security/SecurityConfig·DevSecurityConfig, application-local.yml

[High] P1-8 전역 예외 핸들러 공백 — 4xx가 500으로

문제 NoResourceFound(미존재 URL), HttpMessageNotReadable(JSON 오류), ConstraintViolation/HandlerMethodValidation(@RequestParam 검증), AccessDenied(@PreAuthorize)가 전부 500 INTERNAL_ERROR.

- ☐ 4종 핸들러 추가(404/400/400/403) + 로그 레벨 조정
- ☐ 컨트롤러 로컬 핸들러와 전역 핸들러 정책 통일(메시지 노출 기준 포함)
- ☐ praise admin @PreAuthorize 실패 403 테스트

담당 강태오(common)

위치 common/exception/GlobalExceptionHandler

[High] P1-9 미션·묵상 달력 집계 결함(streak·월경계·스냅샷)

문제 streak이 '오늘 미저장=0'+월경계 절단인데 배치가 04:00 실행이라 STREAK 미션이 사실상 항상 0. 매월 1일 04:00 배치는 새 달만 계산 → 전월 말일 활동 영구 미반영. 미션 target 변경 시 snapshot과 rate 모순. 노트 재저장 시 savedAt 재도장으로 과거 묵상일 소실.

- ☐ streak 정의 확정(어제 anchor 허용·월경계 연속 인정 여부) 후 재구현 — note·mission 계약 명문화
- ☐ 매월 1일 전월 마감 재계산 단계 추가
- ☐ progress_rate를 target_count_snapshot 기준으로 통일(또는 snapshot 동시 갱신)
- ☐ SAVED→SAVED 수정 시 savedAt 보존(최초 저장일 개념 도입)
- ☐ 월경계·04:00 시나리오 테스트

담당 바이블 그룹(mission) · 이지윤·김지민(note)

위치 mission/internal/MissionProgressCalculator, note/internal/MeditationCalendarService·Note

[High] P1-10 journal_events 이벤트 기반 미완(outbox 아님·재처리 0줄)

문제 AFTER_COMMIT+REQUIRES_NEW 기록이라 커밋~기록 사이 크래시 시 무흔적 유실. FAILED/PENDING 재처리가 없음. 이벤트에 previous 값이 없어 증분 집계 불가. 기록 실패가 사용자 500으로 전파.

- ☐ 동일 트랜잭션 PENDING 기록(outbox)으로 전환
- ☐ 재처리 스케줄러 신설(FAILED/PENDING 폴링)
- ☐ 이벤트 스키마에 previousQtPassageId·previousCategory 추가
- ☐ 기록 실패는 swallow + 로그(\$9 필드)로 — 본 응답 오염 방지

담당 이지윤·김지민(note) · 설계 협의: 강태오

위치 note/internal/JournalEventHandler·NoteService

[High] P1-11 study 승인·숨김 경로 비대칭(시뮬레이터/용어 공백)

문제 SIMULATOR/GLOSSARY는 APPROVED row를 만드는 use case 자체가 없고(해설만 완비), ai에서 SIMULATOR 자산을 HIDE해도 클립은 노출 지속. DISABLED는 도달 불가 enum. 승인 시 scene JSON 검증 0.

- ☐ PublishApprovedSimulatorClip/GlossaryTerm UseCase 신설(ai 승인 연동)
- ☐ HidePublishedSimulatorClip UseCase 신설(ai HIDE 전파)
- ☐ DISABLED 반환 조건(운영 토글) 구현
- ☐ 승인 시점 scene_script_json 스키마·크기 검증
- ☐ 사용자 응답의 aiAssetId(내부 PK) 노출 제거 검토

담당 김태혁(study·시뮬레이터) · 강상민(해설/용어·ai 연계)

위치 study/api·internal, ai/internal/AiAssetReviewService

[High] P1-12 Flutter 인증·계약 잔결함

문제 신규회원: 토큰 저장 후 authStatus 미전환 → 재시작 시 닉네임 미설정 채 홈 진입. /auth/** 401에도 refresh+전역 로그아웃(로그인 실패 안내 소실). refresh 연속 실패 시 중복 호출. 2xx success=false 미처리(Null cast 노출). 에러코드→사용자 문구 매핑 부재. 날짜를 기기 로컬 타임존으로 계산(해외에서 어긋남).

- ☐ 신규회원 온보딩 가드(닉네임 설정 전 홈 진입 차단·PopScope)
- ☐ /auth/** 경로는 401 인터셉터 제외
- ☐ refresh single-flight 실패 캐시(중복 발사 방지)
- ☐ 공통 응답 파서(success=false → ApiError) 도입
- ☐ 에러코드(N0004~7, M계열 등)→문구 매핑 레이어
- ☐ 날짜 계산을 서버 passageDate/KST 기준으로 통일

담당 김지민·이승욱·이지윤(Flutter)

위치 lib/core/network/*, lib/features/auth/*

[High] P1-13 알림 미연동·설정 미반영

문제 SendNotificationUseCase 호출자 0건(좋아요/댓글/신고결과 알림 없음). member_settings.notification_enabled 미반영. FK 위반과 eventKey 중복을 같은 catch로 침묵.

- ☐ 좋아요·댓글·신고결과 발송 연결(eventKey 필수화로 역등 보장)
- ☐ 발송 전 notification_enabled 확인 정책 확정·구현
- ☐ FK 위반 vs UK 중복 예외 구분
- ☐ 수신자 존재/탈퇴 검증 추가

담당 김지민·이승욱·이지윤(notification·sharing 연동)

위치 notification/internal/NotificationService, sharing/internal/*

P2 — MSA 분리 준비 (차단 요소 해소) · 8건

[MSA] P2-1 qt의 bible_books native SQL 조인 2건 제거(분리 시 즉시 지점)

문제 Java 경계는 깨끗하지만 SQL이 bible 소유 테이블을 직접 JOIN — ArchUnit 사각지대. DB 분리 순간 깨짐.

- ☐ bible api에 book 코드/영문명→id 매핑 메서드 추가(캐시 활용)
- ☐ QtPassageRepository native 쿼리 2건을 api 호출로 대체
- ☐ SQL 크로스 도메인 접근 금지 가드(테스트 또는 CI grep) 추가

담당 강태오(qt) · 바이블 그룹(bible)

위치 qt/internal/QtPassageRepository

[MSA] P2-2 이벤트 인프라 표준 확정(outbox+릴레이) — Kafka 금지 전제

문제 in-memory ApplicationEvent와 비-outbox 기록뿐이라 분리 시 토대가 없음. § 8상 Kafka 금지.

- ☐ 표준 결정: DB outbox + 폴링 릴레이 vs Redis Stream (Lead 결정)
- ☐ P1-10(journal_events outbox)을 표준 1호 적용 사례로
- ☐ 회원 탈퇴 등 도메인 간 통지가 필요한 이벤트 목록화

담당 강태오(설계) · note 적용: 이지윤·김지민

위치 전역

[MSA] P2-3 공유 식별자·비정규화 전략

문제 bible_verses.id가 qt/note/study/ai 4개 도메인의 공용 키로 고착. 댓글 닉네임 실시간 조회(P0-5) 등 member 의존 다수.

- ☐ verse 자연키(book,chapter,verse) 병기 또는 키 동결 정책 결정
- ☐ 닉네임 등 표시용 데이터 비정규화 원칙 수립(스냅샷 vs 실시간)
- ☐ 사용자 응답에서 내부 PK(aiAssetId 등) 노출 제거

담당 강태오(설계) · 각 도메인

위치 전역

[MSA] P2-4 member purge 단일 트랜잭션 → saga 전환 설계

문제 회원 1명당 7개 도메인 삭제를 한 로컬 트랜잭션으로 묶음 — 분리 시 불가능.

- ☐ MemberPurgeRequested 이벤트 + 도메인별 멱등 삭제 + 완료 추적 설계서 작성
- ☐ 모놀리스 단계에서는 현행 유지하되 도메인별 PurgeUseCase 멱등성 보강
- ☐ audit_logs 내 탈퇴 회원 데이터 처리 정책 결정(개인정보 파기 의무와 충돌 검토)

담당 강태오(member·설계)

위치 member/internal/MemberRetentionPurgeService

[MSA] P2-5 감사(audit) 전략 결정 + 이중 체계 정리

문제 audit_logs는 동기 직접 호출(전 서비스 가용성 결함 우려), admin_action_log는 완전 사장(死藏). 조회 화이트리스트가 AI 자산만이라 기록돼도 조회 불가한 로그 존재.

- ☐ (a) 공통 라이브러리+서비스별 로컬 테이블 vs (b) 비동기 중앙 수집 — 결정
- ☐ admin_action_log 테이블·엔티티 폐기(또는 명시 부활)
- ☐ 조회 화이트리스트 확장(체크리스트/참조작업 액션)
- ☐ before/after_json PII 가드(필드 화이트리스트·크기 제한)

담당 강태오(audit·admin)

위치 audit/*, admin/internal/AdminActionLog*

[MSA] P2-6 ai↔study 결합 정리(승인 원자성·FK 정책)

문제 asset 승인과 verse_explanations 게시가 단일 트랜잭션 원자성에 의존 — 분리 시 보상 흐름 부재. study 테이블의 ai_asset_id FK 정책이 테이블마다 다름(V6 없음/V15 있음).

- ☐ '승인했는데 게시 실패' 보상·재처리 상태 설계
- ☐ V15 ai_asset_id FK 제거 방향으로 통일(분리 대비)
- ☐ P1-11 승인/숨김 계약 완성과 함께 진행

담당 강상민(ai)·김태혁(study)

위치 ai/internal/AiAssetReviewService, V15 마이그레이션

[MSA] P2-7 AI 참조자료 로컬 파일(./restricted) → 스토리지 추상화

문제 검증 참조 인덱스가 단일 인스턴스 로컬 경로 — 멀티 인스턴스/분리 시 인덱스 없는 노드는 검증 전부 NEEDS_REVIEW. 컨테이너 재가동 시 소실.

- ☐ 스토리지 인터페이스 추상화(로컬/오브젝트 스토리지 구현 교체형)
- ☐ 당장은 단일 인스턴스 한계를 기술부채로 명시 등록
- ☐ expires_at 경과 참조자료 자동 제외/스위퍼 추가

담당 강상민(ai)

위치 ai/internal/RestrictedStorageUriResolver 외

[MSA] P2-8 캐시·모듈 가드 보강

문제 todayQt가 인스턴스 로컬 Caffeine — 스케일아웃 시 불일치. Spring Modulith는 § 1 선언과 달리 미도입.

- ☐ todayQt Redis 캐시 전환 검토(이미 Redis 보유)
- ☐ @Cacheable 캐시 key가 주입 Clock을 쓰도록 수정(현재 시스템 시계 SpEL)
- ☐ Spring Modulith 도입 검토 — 모듈 경계 검증·이벤트로 분리 리허설
- ☐ 00:00~04:00 구간 캐시 부재(매 요청 DB) 보완 — 전일 캐시 재사용 또는 짧은 TTL

담당 강태오(인프라·qt)

위치 config/CacheConfig, qt/internal/QtPassageLookup, build.gradle.kts

P3 — 위생 (죽은 코드·게이트·문서) · 5그룹

[정리] P3-1 죽은 코드·중복 일괄 삭제

문제 미구현인데 빈으로 등록된 위험 코드와 사장된 스캐폴딩이 다수.

- ☐ external/kakao 3파일 삭제(미구현 @Component — 주입 시 런타임 폭발 위험)
- ☐ ai/client/qt/GetQtUseCaseMock(@Component 더미) 삭제
- ☐ AdminActionLog·Repository 삭제(P2-5 결정과 함께)
- ☐ study 미구현 큐레이션 7파일·Mock 스켈레톤, praise 스캐폴딩 3파일(유튜브 링크 주석 포함 — § 8 지뢰), report/notification 빈 Mock 2파일 삭제
- ☐ qt의 QtSimulatorResponse/QtStudyContentResponse TODO 스켈레톤 삭제(study가 동일 엔드포인트 구현 완료 — URL 충돌 위험)
- ☐ member 죽은 Settings DTO 2종, AiLogService 미사용 4메서드, sharing isCommentsEnabled() 등 정리

담당 각 도메인 담당(소유 파일별) · 총괄: 강태오
위치 전역

[정리] P3-2 CI·품질 게이트 복구

문제 spectral lint가 루트 apis/ 검사라 영구 skip(실제는 qtai-server/apis). JaCoCo 플러그인 자체가 없어 § 11 명령이 실행 불가(CI는 continue-on-error로 은폐). 금지 번역본 grep은 같은 줄 'KRV' 포함 시 통과. 브랜치명 규칙이 Conventional 타입과 불일치.

- ☐ spectral 경로 수정 + .spectral.yaml 추가
- ☐ build.gradle.kts에 jacoco 플러그인 + coverage verification 를 추가, CI continue-on-error 제거
- ☐ 금지 번역본 grep 보강(라인 화이트리스트 제거, yml/md 확장자 포함)
- ☐ pr-validation 브랜치 타입 목록을 § 12와 정합(feat/fix/refactor 허용)
- ☐ .dockerignore 추가(테스트 키·시드 복사 방지)

담당 강태오(인프라)
위치 .github/workflows/*, build.gradle.kts

[정리] P3-3 OpenAPI 미등재 경로 보완

문제 auth/kakao·qt/today·sharing·member·praise·report·notification·mission·settings·dashboard 등 핵심 경로가 스펙에 없음(27개만 수록). regenerate 등 일부 admin 경로도 누락.

- ☐ 도메인별 담당이 자기 경로 스펙 추가(점진 — P3-2 spectral 게이트 복구 후)
- ☐ 스펙-구현 drift 체크를 PR 체크리스트에 추가

담당 각 도메인 담당 · 취합: 바이블 그룹
위치 qtai-server/apis/api-v1/openapi.yaml

[정리] P3-4 ERD 문서 현행화

문제 qt_passages 구조가 문서와 완전히 다름(절 FK/status/published_at vs 실제 범위 컬럼). ERD에만 있는 테이블 8종, 마이그레이션에만 있는 테이블 5종.

- ☐ 02_ERD_문서를 V1~V23 실 스키마 기준으로 갱신
- ☐ 미구현 테이블(공지·F-15·평가셋 등)은 '계획' 표시로 분리

담당 강태오(문서)
위치 qtai-server/02_ERD_문서.md

[정리] P3-5 설정·주석·문서 오기 정리

문제 마이그레이션 헤더 주석 버전 오기(V9/V10/V11/V23), JwtProvider 'refresh 30일' vs 실제 14일, JacksonConfig가 Boot ObjectMapper 대체(spring.jackson.* 무효), RedisConfig RedisTemplate 빈 미사용, starter-batch 미사용 의존성, CacheConfig bibleBooks 등록만 되고 @Cacheable 미부착.

- ☐ 마이그레이션 헤더·javadoc 수기 정정
- ☐ JacksonConfig→Jackson2ObjectMapperBuilderCustomizer 방식 전환 또는 yml 중복 제거
- ☐ RedisConfig 미사용 빈·starter-batch 의존성 정리
- ☐ listBibleBooks에 @Cacheable("bibleBooks") 부착
- ☐ SU 목상 제목 저장 그레이존 — Lead 판단 후 주석으로 결정 기록

담당 강태오 · 해당 도메인 담당

위치 config/*, db/migration/*, build.gradle.kts

Lead 결정 필요 항목 (코드 수정 전 정책 확정)

- ☐ 관리자 검증 방식: JWT claim vs DB(VerifyAdminRoleUseCase) — P0-1 선결
- ☐ 성서유니온 '목상 제목' 문구 저장 — 저작권 그레이존(본문 텍스트는 미저장으로 확인됨)
- ☐ 삭제 댓글 처리: 행 제외(현 구현) vs '삭제된 댓글입니다' 마스킹(명세) — 대댓글 도입 전 확정
- ☐ 검증 오류 상태코드: 명세 422 vs 구현 400(INVALID_INPUT) — 명세측 수정 권고
- ☐ 로그인 세션: refresh 단일 저장 = 멀티 디바이스 시 이전 기기 로그아웃 — 단일 세션 의도인지
- ☐ 시연 스택 무인증(dev-bypass) 허용 여부 — P1-6
- ☐ 정지(SUSPENDED) 회원의 탈퇴 허용 여부 + 에러코드 분리(M0006 오용 정리)

부록 — 로컬 Git 정리 권고

- ☐ 로컬 dev: origin/dev보다 1커밋 뒤(#254 머지 전) → git switch dev && git pull
- ☐ 로컬 master: origin/master와 7 ahead/14 behind로 어긋남 → git fetch 후 git branch -f master origin/master (master 직접 작업 금지 규칙상 추적용으로만)
- ☐ 손상됐던 .git/index는 6/5 리뷰 중 재구성 완료(작업 트리=HEAD 확인, 손실 없음)